

RealtouchHR

Admin Portal & Full Workspace Control

Production-Ready Feature Specification and Codex/Developer Prompt

Expanded to cover every user-company module visible in the workspace sidebar

Item	Detail
Product	RealtouchHR
Module	Admin Portal / Workspace Control Centre
Purpose	Give each company owner/admin complete control over users, roles, permissions, module access, premium features, security, audit logs, data exports and company-wide settings.
Implementation approach	Audit-first: inspect existing routes, pages, buttons, APIs, database models and permission checks before implementing missing features.
Target status	Production-ready, tenant-isolated, permission-driven, auditable and subscription-aware.
Prepared date	08 June 2026

1. Executive Summary

The Admin Portal must become the central command centre for each user-company workspace. It should not only manage team members; it must control the entire company portal across every module, page, feature, report, action, sensitive data area, AI access point and subscription-gated capability.

The developer must first audit the existing application to confirm what already exists, what is partially implemented, what is missing, and what is unsafe or not production-ready. After the audit, the developer must implement a complete Admin Portal with full workspace-level role-based access control, module controls, feature flags, audit logging, subscription gating, security settings and export controls.

2. Core Principle

The Admin Portal must answer three questions for every company workspace:

1. Who can access this company workspace?
2. What modules, features, reports and actions can each person use?
3. What evidence exists that the workspace is secure, compliant, audited and correctly controlled?

3. Modules That Must Be Covered

The audit and implementation must cover all sidebar modules and related backend features, including modules that appear in different sidebar scroll positions or plan tiers.

Module	Admin Control Scope
Dashboard	Company overview, alerts, KPIs, HR/payroll/UKVI summaries and analytics widgets.
Employees	Employee master records, personal details, employment, documents, payroll readiness, RTW/UKVI status.
Leave	Leave policies, requests, approvals, balances, holiday calendars and absence controls.
Documents	Company and employee document storage, categories, uploads, downloads, expiry alerts and visibility.
Time Tracking	Clock-in/out, timesheets, attendance records, overtime, approvals and payroll-linked time.
Scheduling	Shifts, rotas, work patterns, manager scheduling access and staff visibility.
Payroll	Pay runs, salary access, payslips, deductions, payroll approval and exports.
Statutory Pay	SSP, SMP, SPP, SAP, ShPP and statutory pay calculations/approvals.
Year-End	P60, P45, year-end reports, leaver records and final payroll actions.
HMRC RTI	FPS/EPS configuration, preparation, review, approval, sandbox/live access and submission rights.
RTI Sync	RTI workflow, sync, submission history, HMRC responses and error resolution.
UKVI Compliance	Sponsor compliance, right-to-work, sponsored worker monitoring, scans, reports and alerts.
Import	Bulk employee/payroll/document imports, templates, mapping, validation and rollback.
Audit Log	Immutable activity history, filters, export, sensitive action tracking and admin monitoring.
Self-Service	Employee portal access, profile updates, leave requests, payslip viewing and document visibility.
Enterprise	Company-wide enterprise settings, multi-location, multi-company and advanced controls.
Performance	Reviews, goals, probation, appraisals, feedback, manager access and performance documents.
Policies	Policy library, acknowledgements, staff visibility, versions and reminders.
Training	Training assignment, mandatory courses, certificates, expiry alerts and completion evidence.
HR Analytics	Reports, dashboards, absence trends, headcount, payroll analytics and compliance metrics.
Data Protection	Data privacy workflows, retention, lawful basis records, consent and access restrictions.
GDPR Centre	DSAR workflows, export/delete requests, retention rules and compliance evidence.
Security	MFA, session controls, password policy, API keys, device/session audit and login restrictions.
Trust Badge	Compliance status badge, public/internal trust settings and proof of readiness.
Admin	Company users, invitations, roles, permissions, audit, security and data export.
Super Admin	Platform-owner-only controls; not available to normal company admins.
Billing	Subscription plan, premium modules, invoices, limits and payment status.
Settings	Company profile, HMRC/PAYE settings, payroll settings, notification settings and module defaults.
AI Copilot	AI access, data boundaries, prompt history, usage limits and

4. Audit-First Requirement

Before implementation, the developer/Codex must carry out a structured audit of the current application. The output should be a clear gap report before any major code changes are made.

Audit Area	What to Check	Expected Output
Routes and pages	List every frontend route/page and map to sidebar module.	Route map with owner module and access status.
Buttons and actions	Identify every create, edit, delete, approve, submit, export and view-sensitive-data action.	Action inventory and permission requirement.
Backend APIs	List all API endpoints and check whether each endpoint enforces tenant and permission checks.	Endpoint permission matrix.
Database models	Review user, company, role, permission, subscription, feature flag and audit tables.	Database gap report and migration plan.
Existing permissions	Check whether permissions are frontend-only or enforced at backend level.	Security risk report.
Feature gating	Check whether premium modules/features are subscription-gated.	Plan-feature matrix and missing gates.
Audit logs	Check whether sensitive actions are logged and exportable.	Audit coverage report.
Tenant isolation	Confirm one company cannot access another company's data.	Tenant isolation test results.
Admin UI	Check whether admin can configure roles, modules, security, exports and settings.	UI feature gap report.

5. Required Admin Portal Tabs

Tab	Required Purpose
Overview	Workspace health, subscription status, active users, unresolved alerts, permission risks and recent admin actions.
Team	View users, change roles, remove users, suspend users, resend invites and view last login.
Invites	Invite users, set role before acceptance, expiry controls, revoke invitations and track status.
Roles & Permissions	Create custom roles, assign permissions, clone roles and apply templates.
Modules & Features	Enable/disable modules and configure feature-level access for staff.
Premium Features	Show subscription-gated modules, upgrade prompts and usage limits.
Security	MFA, session timeout, password policy, login controls, device/session management.
Audit Log	View immutable activity logs, filter by user/module/action and export logs.
Data Export	Export company data, module reports and compliance packs with permission checks.

Notifications & Alerts	Configure who receives compliance, payroll, RTI, UKVI, security and expiry alerts.
Company Settings	Company profile, locations, departments, HMRC/PAYE settings, payroll defaults and branding.
Billing	Plan, invoices, premium features, user limits and payment/subscription status.
Danger Zone	Transfer ownership, suspend workspace, delete workspace, irreversible actions with safeguards.

6. Role-Based Access Control Model

The system must use backend-enforced role-based access control (RBAC) with optional custom permissions. Frontend hiding is not enough. Every protected action must be validated server-side.

Role	Default Access Intention
Owner	Full company control, billing, security, role management, live HMRC/RTI approval, danger zone.
Admin	Broad operational control except ownership transfer, billing changes and danger zone unless delegated.
HR Admin	Employee records, documents, leave, policies, training and HR reporting.
Payroll Admin	Payroll, pay runs, statutory pay, year-end, RTI preparation, payroll reports and payslips.
Compliance Manager	UKVI, right-to-work, data protection, GDPR Centre, audit evidence and compliance reports.
Line Manager	Assigned team only: leave approvals, scheduling, timesheets, performance notes and limited employee views.
Employee	Self-service only: own profile, leave requests, documents shared with them, payslips where enabled.
Auditor	Read-only access to specified modules and audit logs; no create/edit/delete/export unless granted.
External Consultant	Configurable limited access by module, time period and data scope.

7. Permission Types Required

- View module
- Create record
- Edit record
- Delete record
- Archive/restore record
- Approve workflow
- Reject workflow
- Submit externally, such as HMRC RTI or UKVI-related report preparation
- Export/download data
- View sensitive fields such as salary, bank details, NI number and visa documents
- Manage settings for the module
- Manage alerts for the module
- Use AI Copilot on the module data
- Bulk import or bulk update module data

- View audit trail for the module

8. Module & Feature Control Centre

The Admin Portal must include a dedicated Module & Feature Control Centre. The company owner/admin should be able to enable, disable, restrict and configure each module and each major feature within that module.

Control	Requirement
Module enabled/disabled	Admin can enable or disable a module for the company, subject to subscription plan.
Role access	Admin can specify which roles can view and use each module.
Feature-level permissions	Admin can control actions such as create, edit, approve, export, delete and submit.
Sensitive data controls	Admin can restrict salary, bank, NI, health, RTW, visa and private notes visibility.
Plan gating	Premium modules/features must show locked state and upgrade path if company is not subscribed.
AI access	Admin can control which roles/modules can use AI Copilot and what data AI can access.
Alert routing	Admin can set who receives alerts from each module.
Audit logging	Changes to module settings must be audit-logged.

9. Workspace Control Matrix

Module	Controls Required	Who Can Configure	Notes
Dashboard	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Employees	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Leave	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Documents	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Time Tracking	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Scheduling	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Payroll	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Statutory Pay	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Year-End	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
HMRC RTI	Enable/disable, view/create/edit/approve/exp	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged

	ort, alert routing, AI access		where sensitive.
RTI Sync	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
UKVI Compliance	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Import	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Audit Log	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Self-Service	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Enterprise	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Performance	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Policies	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Training	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
HR Analytics	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Data Protection	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
GDPR Centre	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Security	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Trust Badge	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Admin	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Super Admin	Platform internal only	Realtouch platform super admins	Never expose to normal company workspace admins.
Billing	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
Settings	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.
AI Copilot	Enable/disable, view/create/edit/approve/export, alert routing, AI access	Owner/Admin plus module-specific roles	All actions must be backend-enforced and audit-logged where sensitive.

10. Sensitive Data Controls

Admin control must protect sensitive information using least-privilege access, field-level permissions, masking and audit logs. Data protection controls should reflect UK GDPR accountability and data protection by design principles from ICO guidance.

Sensitive Area	Control Requirement
Salary/payroll	Visible only to Owner, Payroll Admin or roles explicitly granted salary access.
Bank details	Masked by default; reveal requires permission and must be audit-logged.
NI number	Masked except for authorised payroll/HR users.
Right-to-work and visa documents	Restricted to HR/Compliance roles; downloads logged.
Health/sickness/statutory pay notes	Restricted to HR/Payroll roles and managers only where necessary.
Disciplinary/private HR notes	Restricted; never visible to general line managers unless explicitly assigned.
AI Copilot data	AI must only use data the current user has permission to access.

11. Subscription and Premium Feature Gating

The Admin Portal must integrate with Billing so the company can only access modules/features included in its plan. Premium features should be visible as locked where appropriate, with clear upgrade messaging.

Plan/Feature Requirement	Implementation Detail
Plan feature matrix	Create a canonical matrix defining which modules/features are available per plan.
Premium module lock	Disable backend access if plan does not include the feature, even if UI route is manually opened.
Seat/user limits	Enforce invited/active user limits by plan.
Usage limits	Apply limits for AI Copilot, compliance scans, exports and reports where relevant.
Trial access	Allow time-limited trials with expiry and automatic lock/revert.
Billing status	If subscription is overdue/cancelled, downgrade according to business rules and preserve data.

12. Alerts and Notification Control

Admins must be able to decide who receives alerts and how serious alerts are escalated. Alerts should be both visible in-app and optionally delivered by email where configured.

- Payroll alerts: pay run approval needed, missing payroll data, payroll export completed, unusual payroll changes.
- HMRC RTI alerts: sandbox/live mode status, FPS/EPS ready, submission errors, response received, deadline reminders.
- UKVI alerts: visa expiry, RTW expiry, missing sponsor evidence, compliance scan findings, report-ready status.
- Leave/scheduling alerts: absence conflicts, unauthorised absence, shift changes and manager approvals.
- Security alerts: new login, failed login spike, MFA disabled, role changed, suspicious export/download.
- Data protection alerts: DSAR deadline, retention action due, deletion/export request pending.

- Billing alerts: subscription expiry, premium module lock, seat limit reached.

13. Audit Log Requirements

Every important administrative, security, payroll, RTI, UKVI, data export and sensitive-data action must be logged. Logs should be tamper-resistant and not editable by company admins.

Audit Field	Requirement
Actor	User ID, name, email and role at time of action.
Company/tenant	Company ID and workspace context.
Action	Create, edit, delete, archive, invite, role change, export, approve, submit, login, view sensitive data.
Module	Module where the action happened.
Record	Record ID and type where applicable.
Before/after values	Capture for critical setting/permission changes, masking sensitive values.
Timestamp	UTC timestamp plus display in local time.
IP/device/session	Capture where available.
Outcome	Success, failure, blocked, permission denied.
Reason/comment	Required for sensitive changes such as salary edit, role change, live RTI submission, data deletion.

14. Security Requirements

- All permission checks must be enforced on the backend/API layer.
- Tenant isolation must be enforced on every query and mutation.
- The Owner role must not be removable unless ownership is transferred first.
- Danger Zone actions must require re-authentication, typed confirmation and audit logging.
- MFA should be configurable, with optional enforcement for admins and payroll/compliance users.
- Session timeout and concurrent session controls should be configurable.
- API keys, HMRC credentials, bank data and sensitive configuration must never be exposed in logs or client-side responses.
- Exports must require permission and create an audit event.
- AI Copilot must not bypass permissions or retrieve restricted data.

15. Data Export and Data Protection Controls

Data export and privacy controls should support UK GDPR-aligned accountability, including data minimisation, access controls, retention rules, DSAR support and records of administrative actions.

Control	Requirement
Company export	Owner/Admin can export company data based on permissions and plan limits.
Module export	Export by module: employees, payroll, leave, documents, UKVI, audit logs, policies, training.
DSAR workflow	Admin can collect/export employee data subject to role and approval controls.
Retention settings	Configure default retention periods for documents, leavers, audit logs and HR records.
Deletion controls	Hard delete should be restricted; soft delete/archive preferred with retention/audit trail.

Export watermark	Optional watermark/report footer with company, user and timestamp.
------------------	--

16. Admin UX Requirements

- Use the existing RealtouchHR design system: clean white cards, purple primary buttons, subtle borders, badges and clear warnings.
- Admin controls should be grouped by module and role, not hidden across multiple unrelated pages.
- Use clear status badges: Enabled, Disabled, Premium, Locked, Missing Permission, Inherited, Custom, High Risk.
- Add a global search in Admin Portal for users, roles, modules, permissions, settings and audit events.
- Display a clear warning before disabling modules used by staff or workflows.
- Provide a preview of permission impact before saving major changes.
- Show when a permission is blocked by subscription plan even if an admin tries to grant it.

17. Recommended Data Model

Suggested database entities/tables:

companies
users
company_users
roles
permissions
role_permissions
user_permissions_overrides
modules
features
company_module_settings
company_feature_flags
subscription_plans
plan_features
company_subscriptions
invitations
audit_logs
security_settings
notification_rules
export_jobs
api_keys
sessions
admin_action_approvals
ai_access_policies

18. Required API/Backend Coverage

API Area	Required Endpoints/Functions
Users	List company users, invite user, revoke invite, suspend user, remove user, transfer ownership.
Roles	List roles, create custom role, clone role, update role, delete role, assign role.

Permissions	List permissions, evaluate permissions, update role permissions, update user overrides.
Modules/features	List modules/features, update company module settings, update feature flags, check plan gate.
Security	Update MFA policy, session policy, password policy, view sessions, revoke sessions.
Audit	Search audit logs, export audit logs, view sensitive-action logs.
Exports	Create export job, download export, track export status, delete generated export.
Billing/plan	Get plan, get plan features, check usage limits, handle locked features.
Notifications	Get/update alert routing and escalation rules.
AI policy	Set AI module access, data boundaries and usage limits.

19. Production Readiness Test Plan

Test Category	Acceptance Criteria
Audit completeness	Every sidebar module, route, API endpoint and action is listed in the audit report.
Backend permissions	A user cannot perform restricted actions through direct API calls.
Tenant isolation	Users from Company A cannot access Company B data by changing IDs or URLs.
Role changes	Admin can grant/revoke access and changes take effect immediately.
Module disable	Disabled modules disappear or lock in UI and are blocked by API.
Premium gating	Locked premium modules cannot be accessed without active subscription.
Sensitive data masking	Bank/salary/NI/visa fields are masked unless user has explicit permission.
Audit logging	Critical actions create audit events with actor, module, outcome and timestamp.
Exports	Only authorised users can export; all exports are logged.
AI boundaries	AI Copilot cannot answer using data the user is not permitted to view.
Danger Zone safety	Danger actions require confirmation, re-authentication and are logged.
Regression	Existing modules still work after permission integration.

20. Definition of Done

- A full audit report exists showing existing, partial and missing admin-control features.
- Every sidebar module is registered in the permission/module control system.
- Every protected route is guarded on the frontend and backend.
- Every protected API endpoint checks company tenancy and permission.
- Company admins can manage users, roles, permissions, module access, alert routing and exports.
- Premium feature gating is connected to the billing/subscription model.
- Sensitive fields are masked by default and require permission to reveal/export.
- Audit logs capture all critical admin, security, data, payroll, RTI and UKVI actions.
- AI Copilot respects role, module, feature and data-level permissions.

- Production tests pass and no company can access another company's data.

21. Comprehensive Codex/Developer Prompt

Copy and paste the prompt below into Codex or send it directly to your software developer.

You are working on the RealtouchHR application. I need you to audit and upgrade the Admin Portal so that each company owner/admin has full, production-ready control over their entire company workspace, not only team management.

IMPORTANT CONTEXT

The current sidebar/modules across RealtouchHR include: Dashboard, Employees, Leave, Documents, Time Tracking, Scheduling, Payroll, Statutory Pay, Year-End, HMRC RTI, RTI Sync, UKVI Compliance, Import, Audit Log, Self-Service, Enterprise, Performance, Policies, Training, HR Analytics, Data Protection, GDPR Centre, Security, Trust Badge, Admin, Super Admin, Billing, Settings and AI Copilot.

GOAL

Build a full Admin Portal / Workspace Control Centre that allows each company owner/admin to control:

- Users and invitations
- Roles and permissions
- Access to every module
- Access to every feature/action inside each module
- Sensitive data visibility
- Premium/subscription-gated features
- Alerts and notification routing
- Security settings
- Audit logs
- Data exports
- Company-wide settings
- AI Copilot access and data boundaries

PHASE 1 - AUDIT FIRST

Before implementing changes, audit the existing application and produce a clear Admin Control Gap Report. The audit must inspect:

1. All frontend routes/pages.
2. All sidebar modules and hidden/module-tier routes.
3. All buttons/actions including view, create, edit, delete, archive, approve, reject, submit, export, download, import and view-sensitive-data.
4. All backend API endpoints and server actions.
5. All database models/tables related to users, companies, roles, permissions, subscriptions, feature flags and audit logs.
6. Existing permission checks and whether they are frontend-only or backend-enforced.
7. Existing subscription/premium feature gating.
8. Existing audit logging coverage.
9. Existing tenant isolation controls.
10. Existing AI Copilot access controls.

The audit output must classify each feature as:

- Existing and production-ready
- Existing but incomplete
- Existing but insecure
- Missing
- Blocked by missing data/model/API

PHASE 2 - DESIGN THE CONTROL MODEL

Implement or complete a backend-enforced RBAC/permission model with:

- companies

- users
- company_users
- roles
- permissions
- role_permissions
- user_permission_overrides where needed
- modules
- features
- company_module_settings
- company_feature_flags
- subscription_plans
- plan_features
- company_subscriptions
- invitations
- audit_logs
- security_settings
- notification_rules
- export_jobs
- ai_access_policies

Do not rely only on hiding buttons in the frontend. Every protected route, API endpoint and server action must enforce tenant isolation and permission checks.

PHASE 3 - ADMIN PORTAL TABS

Upgrade the Admin Portal to include these tabs:

1. Overview - workspace health, active users, subscription status, unresolved alerts, recent admin actions and permission risks.
2. Team - list users, roles, last login, status, suspend/remove users, transfer ownership safeguards.
3. Invites - invite users, assign role before acceptance, revoke/resend invite, expiry status.
4. Roles & Permissions - create/edit/clone roles, assign permissions, custom role templates.
5. Modules & Features - enable/disable modules, assign role access by module and feature.
6. Premium Features - show subscription-gated modules, locked features, usage limits and upgrade prompts.
7. Security - MFA policy, session timeout, password policy, login/session control and device management.
8. Audit Log - immutable logs with filters by user, module, action, date and export.
9. Data Export - export permitted company/module data with audit logging.
10. Notifications & Alerts - configure who receives compliance, payroll, HMRC RTI, UKVI, security and billing alerts.
11. Company Settings - company profile, departments, locations, branding, payroll/HMRC settings where permitted.
12. Billing - plan, invoices, subscription status, user limits and premium modules.
13. Danger Zone - ownership transfer, workspace suspension/deletion, irreversible actions with re-authentication and typed confirmation.

PHASE 4 - MODULE CONTROL REQUIREMENTS

For every module, admin must be able to control at least:

- Whether the module is enabled for the company.
- Which roles/users can view the module.
- Which roles/users can create records.
- Which roles/users can edit records.
- Which roles/users can delete/archive records.
- Which roles/users can approve/reject workflows.
- Which roles/users can export/download data.
- Which roles/users can view sensitive data.
- Which roles/users can manage settings for that module.
- Which roles/users can receive alerts for that module.
- Which roles/users can use AI Copilot on that module's data.

PHASE 5 - MODULES TO INCLUDE

Apply the above control model to all modules:

Dashboard, Employees, Leave, Documents, Time Tracking, Scheduling, Payroll, Statutory Pay, Year-End, HMRC RTI, RTI Sync, UKVI Compliance, Import, Audit Log, Self-Service, Enterprise, Performance, Policies, Training, HR Analytics, Data Protection, GDPR Centre, Security, Trust Badge, Admin, Billing, Settings and AI Copilot.

Super Admin must be treated separately as a Realtouch platform-level area only. It must not be exposed to normal company owners/admins unless they are internal platform super admins.

PHASE 6 - DEFAULT ROLES

Implement sensible default roles:

- Owner
- Admin
- HR Admin
- Payroll Admin
- Compliance Manager
- Line Manager
- Employee
- Auditor
- External Consultant

Allow custom roles where appropriate, but prevent unsafe changes such as removing the last Owner.

PHASE 7 - SENSITIVE DATA PROTECTION

Protect sensitive data with field-level permissions, masking and audit logs. This includes:

- Salary
- Bank details
- NI number
- Right-to-work documents
- Visa/UKVI documents
- Health/sickness/statutory pay data
- Disciplinary notes
- Private HR notes
- HMRC credentials/configuration
- Data exports

Bank details and other sensitive fields should be masked by default. Revealing, downloading or exporting sensitive data must be permission-controlled and audit-logged.

PHASE 8 - SUBSCRIPTION AND PREMIUM GATING

Connect module/feature access to Billing/subscription. Premium features must be enforced at backend level, including but not limited to:

- UKVI comprehensive compliance scan
- Advanced HR analytics
- AI Copilot advanced usage
- Advanced data export/compliance packs
- Enterprise controls
- Advanced RTI automation if applicable

Users should see locked premium features where appropriate, but direct API access must be blocked without an active plan entitlement.

PHASE 9 - AUDIT LOGGING

Ensure audit logs are immutable and capture:

- Actor user ID, name, email and role
- Company/tenant ID

- Module
- Action
- Record type and record ID
- Timestamp
- IP/device/session if available
- Outcome: success, failure, permission denied
- Before/after values for critical settings, with sensitive values masked
- Reason/comment where required

Log all critical actions: invite, role change, permission change, module enable/disable, export, salary view/change, bank view/change, document download, HMRC RTI submit, UKVI report download, AI access policy change, security setting change and danger zone action.

PHASE 10 - AI COPILOT ACCESS CONTROL

AI Copilot must only access data the current user is permitted to access. If a user cannot view salary, bank details, visa documents, payroll data, UKVI records, audit logs or sensitive notes directly, AI Copilot must not reveal or summarise that data.

PHASE 11 - TESTING AND ACCEPTANCE CRITERIA

Implement automated and manual tests proving:

1. Every protected API endpoint enforces tenant isolation.
2. Users from one company cannot access another company's data.
3. Frontend hiding is not the only security mechanism.
4. Role changes take effect immediately.
5. Disabled modules are blocked by frontend and backend.
6. Premium modules are blocked without subscription entitlement.
7. Sensitive data is masked unless explicit permission exists.
8. Exports are permission-controlled and audit-logged.
9. Audit logs are generated for all critical admin actions.
10. AI Copilot respects permissions and cannot leak restricted data.
11. The last Owner cannot be removed or downgraded.
12. Danger Zone actions require re-authentication, typed confirmation and logging.
13. Existing modules continue working after permissions are applied.

DELIVERABLES REQUIRED

1. Admin Control Gap Report.
2. Database migration plan and implemented migrations.
3. Backend permission/tenant enforcement layer.
4. Frontend Admin Portal upgrade.
5. Module & Feature Control Centre.
6. Subscription/feature gating integration.
7. Audit log integration.
8. Security settings integration.
9. Tests and acceptance report.
10. Production readiness summary.

Do not mark the work complete until the Admin Portal can control the whole company workspace across all modules, all sensitive actions are audit-logged, all permissions are backend-enforced, and subscription gates are enforced in both frontend and backend.

22. Official Reference Points for Developer Awareness

These references are included for awareness because the Admin Portal includes data protection, UKVI compliance, audit and security controls. They should be reviewed by the product/legal/compliance owner where relevant:

- ICO guidance on data protection by design and by default: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/accountability-and-governance/guide-to-accountability-and-governance/data-protection-by-design-and-by-default/>
- ICO guide to accountability and governance: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/accountability-and-governance/guide-to-accountability-and-governance/>
- GOV.UK sponsor duties and compliance guidance: <https://www.gov.uk/government/publications/workers-and-temporary-workers-guidance-for-sponsors-part-3-sponsor-duties-and-compliance>
- GOV.UK sponsor record-keeping duties Appendix D: <https://www.gov.uk/government/publications/keep-records-for-sponsorship-appendix-d>

Appendix A - Quick Admin Control Checklist

Area	Pass Condition
Users and invites	Can owner invite, suspend, remove, revoke, resend, transfer ownership safely?
Roles	Can owner create/clone/edit roles and assign granular permissions?
Modules	Can owner enable/disable every company module?
Features	Can owner restrict key actions inside each module?
Sensitive data	Are salary, bank, NI, RTW, visa, health and private notes protected?
Premium features	Are locked features enforced by plan on frontend and backend?
Security	Can owner configure MFA/session/password policies?
Audit	Are critical actions immutable and exportable by permission?
Exports	Are data exports permission-controlled and logged?
AI	Does AI obey the same access rules as the user?
Tenant isolation	Can no user access another company workspace/data?